

CYBER INCIDENT REPORTING PORTAL (CIRP)

Software Requirements / Requirements Report
Project Type: SDLC / Software Engineering Academic Project

Document Version: 1.0
Prepared as part of academic coursework (Software Engineering / SDLC)

1. Introduction

1.1 Project Title

Cyber Incident Reporting Portal (CIRP)

1.2 Purpose

The Cyber Incident Reporting Portal is a web-based application designed to provide employees and system users of an organization with a structured, confidential and trackable way to report suspected or confirmed cybersecurity incidents — such as phishing, malware infection, unauthorized access, data leakage, denial-of-service activity and policy violations — and for the organization's security team to triage, investigate, contain and resolve those incidents. The portal supports incident tracking, escalation, evidence handling, notifications, compliance-oriented reporting, and selected AI-assisted features such as automatic incident categorization and severity prediction.

2. Problem Statement

Many organizations still rely on ad-hoc channels — emails, phone calls, verbal reports or scattered spreadsheets — for employees to report suspected security incidents. These approaches create the following problems:

- Lack of a centralized system for logging and tracking cyber incidents.
- Delayed reporting and delayed response to active threats.
- Difficulty determining the severity and business impact of a reported incident.
- Incidents being routed to the wrong analyst or team.
- No structured chain of custody for digital evidence (screenshots, logs, emails).
- Lack of accountability and audit trail during investigation and containment.
- Difficulty identifying incidents that are breaching response-time SLAs or regulatory deadlines.
- Poor communication back to the reporting employee about incident status.
- Difficulty generating compliance and management reports after an incident.
- Duplicate reports for the same underlying incident (e.g., a widespread phishing campaign).

Therefore, a centralized Cyber Incident Reporting Portal is proposed to improve response speed, accountability, evidence integrity, and regulatory compliance in handling cybersecurity incidents.

3. Objectives

- Provide employees/users with a simple, confidential platform to report cyber incidents.
- Provide each incident with a unique incident reference ID.
- Allow reporters to track the status of their reported incident.
- Classify incidents according to standard cyber incident categories.
- Route incidents to the appropriate security analyst or response team.
- Allow security analysts to triage, verify and prioritize incidents.

- Allow analysts to assign incidents to incident response (IR) team members.
- Allow IR team members to log investigation steps and containment actions.
- Allow evidence (logs, screenshots, files, network captures) to be attached securely.
- Allow supervisors to verify closure and root-cause analysis before an incident is closed.
- Notify stakeholders about important status changes and SLA breaches.
- Track response-time and resolution-time metrics against defined SLAs.
- Identify overdue/escalated incidents and support escalation to management.
- Provide dashboards and reports for the security team and management (CISO-level view).
- Use AI to assist with incident classification, severity prediction and duplicate detection.
- Support optional anonymous reporting to encourage whistleblowing on internal misuse.
- Improve organizational security posture, compliance and audit-readiness.

4. Scope of the System

4.1 Reporter / Employee Scope

- Register/authenticate using organizational credentials (SSO where available).
- Login/logout and manage profile.
- Submit a cyber incident report (or submit anonymously, where permitted).
- Select incident category and affected system/asset.
- Provide description, date/time of occurrence, and impact observed.
- Upload evidence (screenshots, emails, logs, files).
- Track incident status and view resolution timeline.
- View history of previously submitted incidents.
- Receive notifications on status changes.
- Respond to follow-up questions from the analyst.

4.2 Security Analyst Scope

- View, search and filter incoming incident reports.
- Verify and validate reported incidents.
- Reject false positives or duplicate reports, with justification.
- Classify/re-classify incident type and set severity (Critical/High/Medium/Low).
- Assign incidents to the appropriate response team or analyst.
- Set investigation deadlines aligned to SLA/regulatory timelines.
- Monitor investigation progress across assigned incidents.
- Review containment and remediation evidence.
- Approve or reject incident closure; reopen incidents if required.
- Escalate overdue or high-severity incidents to management.
- Generate incident and compliance reports.

4.3 Incident Response (IR) Team Member Scope

- Login and view assigned incidents.
- View incident details, affected assets and attached evidence.
- Log investigation steps, findings and containment/remediation actions.
- Upload additional evidence and forensic notes.
- Update chain-of-custody log for evidence handled.
- Mark an assigned incident as contained / resolved, pending analyst verification.
- View pending and completed assignments.

4.4 Administrator Scope

- Manage users, analysts and IR team members.

- Manage departments/teams and asset inventory references.
- Manage incident categories, severity matrix and SLA rules.
- Manage system settings and notification templates.
- Monitor system activity and audit logs.
- Generate organization-wide security incident reports.

5. Stakeholders

Stakeholder	Role
Employees / Users	Report suspected or confirmed cyber incidents
Security Analysts	Triage, verify, classify and prioritize incidents
Incident Response Team	Investigate, contain and remediate incidents
System Administrator	Manage the overall system and configuration
Management / CISO	Monitor organizational security posture and compliance
Compliance / Legal Team	Review incidents with regulatory or legal implications

6. User Roles

Role	Description
Reporter / Employee	Can submit and track their own incident reports (optionally anonymously).
Security Analyst	Can triage, classify, prioritize and assign incidents within their scope.
IR Team Member	Can investigate and act on incidents assigned to them.
Administrator	Has system-level configuration and management privileges.

7. Functional Requirements

ID	Requirement
FR-01	User Registration & SSO: The system shall allow users to authenticate via organizational SSO or a registered account (name, email, department, password).
FR-02	User Login: The system shall authenticate registered users and redirect them to the dashboard corresponding to their role.
FR-03	Role-Based Access Control: The system shall enforce distinct permissions for Reporter, Security Analyst, IR Team Member and Administrator.
FR-04	Incident Registration: Reporters shall submit a title, description, category, affected asset/system, date/time of occurrence, and supporting evidence. A unique incident ID shall be generated.
FR-05	Anonymous Reporting: The system shall allow a reporter to optionally submit an incident anonymously, withholding their identity from analysts unless legally required.
FR-06	Incident Categorization: The system shall support categories such as Phishing, Malware/Ransomware, Unauthorized Access, Data Leakage, Denial of Service, Insider Misuse, Physical Security, and Other.
FR-07	Asset/System Association: Reporters and analysts shall associate an incident with one or more affected systems, applications or assets from an asset reference list.
FR-08	Evidence Upload: Users shall upload screenshots, log files, emails (as attachments) or other supported evidence associated with an incident.
FR-09	Incident ID Generation: The system shall automatically generate a unique incident identifier, e.g. CIRP-2026-00125.
FR-10	Incident Verification & Triage: Security analysts shall review incidents, verify or reject them (false positive/duplicate), and may re-classify category or severity.
FR-11	Severity Classification: Analysts shall assign a severity level (Critical, High, Medium, Low) based on impact and likelihood, following a defined severity matrix.
FR-12	Team/Analyst Assignment: Verified incidents shall be assigned to an appropriate IR team member or team, with incident ID, severity, SLA deadline and assignment timestamp recorded.
FR-13	Incident Status Management: The system shall maintain statuses such as Reported, Under Triage, Verified, Assigned, Investigating, Contained, Resolved, Reopened and Closed.
FR-14	Incident Tracking: Reporters shall be able to track the current status of their incident and view a status timeline (excluding confidential investigation details).
FR-15	Investigation Logging: IR team members shall log investigation steps, findings and containment/remediation actions against the incident.
FR-16	Chain-of-Custody Logging: The system shall maintain a timestamped, immutable log of who accessed or handled each piece of evidence.

ID	Requirement
FR-17	Resolution Verification: Analysts shall approve closure, reject and request further investigation, or reopen a resolved incident.
FR-18	Incident Reopening: An incident may be reopened by an analyst if new information emerges or the reporter disputes the resolution.
FR-19	Notifications: The system shall notify relevant users on submission, verification, assignment, status change, SLA breach and closure.
FR-20	SLA / Deadline Management: Analysts shall define response and resolution deadlines per severity level; the system shall flag incidents exceeding those deadlines.
FR-21	Escalation: The system shall automatically escalate overdue or unacknowledged high/critical severity incidents to management.
FR-22	Search and Filtering: Analysts and administrators shall filter incidents by ID, category, severity, status, assigned analyst/team, asset and date range.
FR-23	Dashboard: The system shall provide role-specific dashboards (reporter, analyst, IR team, administrator/management).
FR-24	Reports: The system shall generate reports by category, severity, status, department, asset, date range, response time and resolution time, suitable for internal review and regulatory submission.
FR-25	Audit Trail: The system shall maintain a tamper-evident audit log of all status changes, assignments and access to incident records.

8. AI-Based Functional Requirements

ID	Requirement
AI-FR-01	Automatic Incident Classification: The system may analyze the reporter's free-text description and suggest a category/subcategory (e.g., phishing vs. malware). Reporters and analysts can accept or override the suggestion.
AI-FR-02	Severity Prediction: The system may analyze incident details (category, affected asset, description) and suggest a severity level. The final severity decision remains with the security analyst.
AI-FR-03	Duplicate / Related Incident Detection: The system may compare a new incident against recent open incidents to flag likely duplicates or a related campaign (e.g., the same phishing email reported by multiple employees).
AI-FR-04	Suspicious Content Flagging: The system may perform a preliminary automated scan of uploaded evidence (e.g., URLs, attachment names) and flag common indicators of compromise for analyst attention.

9. Non-Functional Requirements

ID	Requirement
NFR-01	Performance: Normal user requests should respond within approximately 3 seconds under normal load.
NFR-02	Security: Use secure authentication, password hashing/SSO, role-based authorization, encryption of evidence at rest and in transit, input validation, and protection of sensitive incident data.
NFR-03	Confidentiality: Incident details and reporter identity shall be visible only to authorized roles; anonymous reports shall not reveal reporter identity to analysts or IR team members.
NFR-04	Usability: Provide simple navigation, clear incident submission flow, clear status indicators and a responsive design usable on desktop and mobile.
NFR-05	Reliability: Maintain incident and evidence data reliably and prevent accidental data loss during normal operation.
NFR-06	Availability: The system should be available at all times, including outside business hours, since incidents may occur at any time.
NFR-07	Scalability: The system should support an increasing number of users, incidents, assets, analysts and IR team members.
NFR-08	Maintainability: Use a modular architecture so new incident categories, severity rules and workflows can be added with minimal changes.
NFR-09	Compatibility: Support modern browsers such as Chrome, Edge and Firefox.

ID	Requirement
NFR-10	Auditability: All access to and modification of incident records shall be logged in a tamper-evident audit trail for compliance review.
NFR-11	Backup and Recovery: The database and evidence store should be backed up periodically so incident information can be recovered after a system failure.
NFR-12	Regulatory Alignment: The system's timelines and reporting fields should be configurable to align with applicable regulatory reporting requirements (e.g., mandated reporting windows).

10. External Interface Requirements

10.1 User Interface

- Reporter: registration/SSO login, dashboard, incident submission, tracking and notifications.
- Security Analyst: dashboard, triage queue, classification, assignment and reports.
- IR Team Member: dashboard, assigned incidents, investigation log and evidence upload.
- Administrator: user, team and category management, dashboard and organization-wide reports.

10.2 Software Interfaces

- MongoDB / relational database for structured incident data.
- Organizational SSO / identity provider for authentication.
- Encrypted file/evidence storage service.
- Notification service (email, and optionally SMS).
- Optional integration with SIEM/log-management tools for supporting evidence.

10.3 Hardware Interfaces

- Desktop computers
- Laptops
- Tablets
- Smartphones (for on-the-go reporting and evidence capture)

11. Proposed Technology Stack

Layer	Technology
Frontend	React.js
Styling	CSS / Tailwind CSS
Backend	Node.js
Backend Framework	Express.js
Database	MongoDB
Database Management	MongoDB Compass
Authentication	JWT (+ SSO/OAuth2 integration)
Password Security	bcrypt
File Upload	Multer
Evidence Storage	Cloudinary / encrypted cloud storage
Charts	Recharts

Layer	Technology
API Testing	Postman
Version Control	Git + GitHub
Development Environment	VS Code

12. System Architecture

```

CYBER INCIDENT REPORTING PORTAL
REPORTER / ANALYST / IR TEAM / ADMIN
|
React Frontend
|
REST API
|
Node.js + Express
|
+-----+-----+
| | |
MongoDB Evidence SSO /
Database Storage Identity
| (encrypted) Provider
|
AI Services
Classification / Severity /
Duplicate Detection

```

13. Incident Lifecycle

```

Employee/User reports incident (optionally anonymous)
|
Incident ID generated
|
Incident under triage
|
Analyst verifies incident
|
Valid?
/ \
No Yes
| |
Rejected Severity assigned
|
IR team assigned
|
Investigation in progress
|
Containment & remediation evidence
|
Analyst verification
/ \
No Yes
| |
Reopened Resolved
|
Root-cause review
|
Closed

```

14. Business Rules

- A user must be authenticated before submitting a non-anonymous incident report.
- Every incident must have a unique incident ID.
- Every incident must belong to a valid category.
- Only authorized security analysts can verify and classify incidents.
- Only authorized analysts can assign incidents to IR team members.
- An IR team member can update only incidents assigned to them.
- Evidence must be logged with a timestamped chain-of-custody entry whenever accessed or modified.
- An incident should have documented containment/remediation evidence before it is marked resolved.
- Only an authorized analyst can verify final resolution and closure.
- Anonymous reports shall not expose reporter identity to analysts or IR team members.
- Critical and High severity incidents must be escalated automatically if unacknowledged within the defined SLA window.
- AI-generated classifications and severity suggestions are recommendations; analysts retain final authority.
- Users cannot access information or functionality outside their assigned role.

15. Assumptions

- Users have access to the organization's network or a secure remote connection.
- Users provide reasonably accurate information when reporting an incident.
- Security analysts and IR team members are registered in the system in advance.
- Security analysts are responsible for verifying and classifying incidents.
- IR team members have the tools/access needed to investigate assigned systems.
- Uploaded evidence complies with supported formats and size limits.
- AI predictions are advisory and may require human verification.

16. Constraints

- Network/internet connectivity is required to access the portal.
- AI prediction quality depends on the volume and quality of historical incident data.
- Evidence storage requirements grow with the number and size of file attachments.
- Analysts and IR staff must update incident status accurately for reporting to remain reliable.
- Some advanced features (SIEM integration, SSO) may require third-party services.
- The initial project may be a prototype rather than a production security-operations deployment.

17. Feasibility Analysis

17.1 Technical Feasibility

The system can be developed using widely available technologies such as React.js, Node.js, Express.js and MongoDB, along with standard encryption and authentication libraries. Therefore, the project is technically feasible.

17.2 Economic Feasibility

The prototype can use open-source technologies and free/developer-tier services, keeping development cost low.

17.3 Operational Feasibility

The system is designed to simplify incident reporting for employees and streamline triage, investigation and closure for the security team. Therefore, it is operationally feasible.

17.4 Schedule Feasibility

The project can be developed in phases: requirement analysis, system design, database design, frontend development, backend development, integration, testing and deployment.

18. Security Requirements

- Secure authentication (SSO/JWT-based).
- Password hashing where local accounts are used.
- Role-based access control enforced on every API endpoint.
- Encryption of evidence and sensitive incident data at rest and in transit.
- Input validation and file type/size validation for evidence uploads.
- Protection against unauthorized API access.
- Tamper-evident audit logging of all access and status changes.
- Confidentiality safeguards for anonymous reports.
- Proper session/token management and timely session expiry.

19. Testing Requirements

Unit Testing

Individual functions and modules (e.g., severity calculation, ID generation) shall be tested independently.

Integration Testing

Interactions between frontend/backend, backend/database and external services (SSO, storage) shall be tested.

System Testing

The complete incident lifecycle shall be tested from reporting through closure.

Security Testing

Unauthorized access, role permissions and confidentiality of anonymous reports shall be tested.

Usability Testing

The system shall be evaluated for ease of incident submission and status tracking.

User Acceptance Testing

Representative employees, analysts and IR team members shall evaluate whether the system meets requirements.

20. Success Criteria

- Users can register/authenticate and log in successfully.
- Users can submit incidents, including anonymously.
- Every incident receives a unique ID.
- Incidents can be classified, prioritized and assigned.
- Analysts can verify and triage incidents.
- IR team members can receive assignments and log investigation actions.
- Evidence can be uploaded with a chain-of-custody log.
- Analysts can verify resolution and closure.
- Reporters can track incident status without seeing confidential details.
- Overdue/high-severity incidents can be identified and escalated.
- Reports can be generated for internal and compliance purposes.
- Role-based access works correctly, including anonymous-report confidentiality.
- AI modules provide useful recommendations without preventing normal incident processing.

21. Future Enhancements

- AI-powered indicator-of-compromise (IOC) extraction from evidence.
- AI chatbot to guide employees through incident reporting.
- Direct SIEM/EDR integration for automatic incident creation from alerts.
- Mobile application for Android/iOS for faster field reporting.
- SMS and messaging-app notifications for critical escalations.
- Automated regulatory report generation for applicable authorities.
- Advanced analytics and predictive dashboards for recurring threat patterns.
- Integration with threat-intelligence feeds for enrichment.
- Playbook automation for common incident types (e.g., automated account lockout on phishing confirmation).

22. Conclusion

The Cyber Incident Reporting Portal provides a centralized solution for reporting, triaging, investigating and resolving cybersecurity incidents within an organization. The system connects employees with the security team and incident response staff through a structured, auditable incident lifecycle. It improves response speed and accountability through tracking, evidence chain-of-custody, SLA-based escalation and status history, while dashboards and reports help the security team and management monitor organizational security posture.

AI-assisted classification, severity prediction and duplicate detection can further improve triage efficiency while keeping final decisions under human (analyst) supervision. The proposed system is technically, economically and operationally feasible, and can serve as a foundation for a scalable organizational security-operations support platform.